

ROAD TO HALL OF FAME - ACTIVIDAD 12

FILE PATH TRAVERSAL, VALIDATION OF FILE EXTENSION WITH NULL BYTE BYPASS

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

Datos del Laboratorio	3
Marco Teórico y Fundamentación Técnica	3
Procedimiento	4
Explicación del Payload	6
Mitigación Recomendada.....	6
Referencias	7

Datos del Laboratorio

- **Nombre del laboratorio:** *File path traversal, validation of file extension with null byte bypass*
- **Nivel:** Practitioner
- **Tipo de Explotación:** File Path Traversal
- **Objetivo del laboratorio:** Explorar la vulnerabilidad de File Path Traversal a través del método de petición "GET" del protocolo HTTP, con el fin de poder leer el archivo `/etc/passwd`.

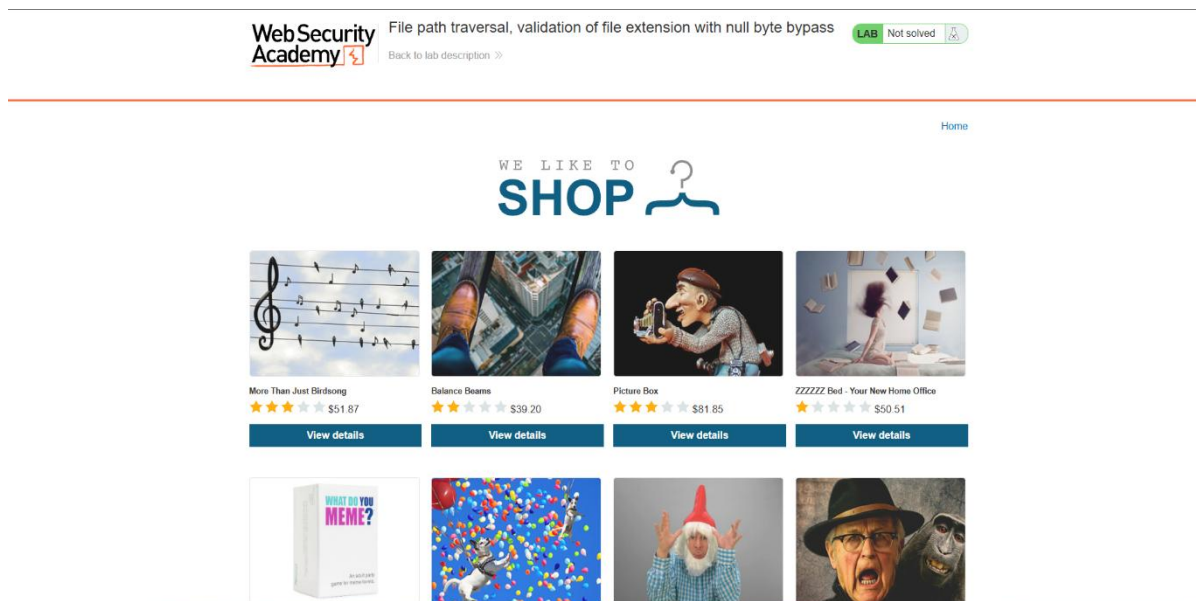
Marco Teórico y Fundamentación Técnica

Concepto: De acuerdo con OWASP, un ataque de *Path Traversal* (también conocido como *Directory Traversal*) tiene como objetivo acceder a archivos y directorios que están almacenados fuera de la carpeta raíz web. Al manipular las variables que hacen referencia a los archivos usando secuencias de "punto-punto-barra" (`../`) o rutas absolutas permite a un atacante acceder a archivos y directorios en el sistema de archivos, incluyendo código fuente de la aplicación, configuraciones y archivos críticos del sistema. En el caso particular de este laboratorio, la aplicación valida que la cadena recibida en el parámetro `filename` termine con una extensión de archivo permitida (por ejemplo, `.jpg`), asumiendo que esto garantiza que solo se acceda a imágenes legítimas. Sin embargo, es posible insertar un **byte nulo** (`%00`) entre la ruta maliciosa y la extensión exigida. Muchos lenguajes de bajo nivel interpretan el byte nulo como el terminador de una cadena de texto (heredado de C), por lo que el sistema de archivos ignora todo lo que viene después de él, incluyendo la extensión `.jpg` que solo estaba ahí para satisfacer la validación.

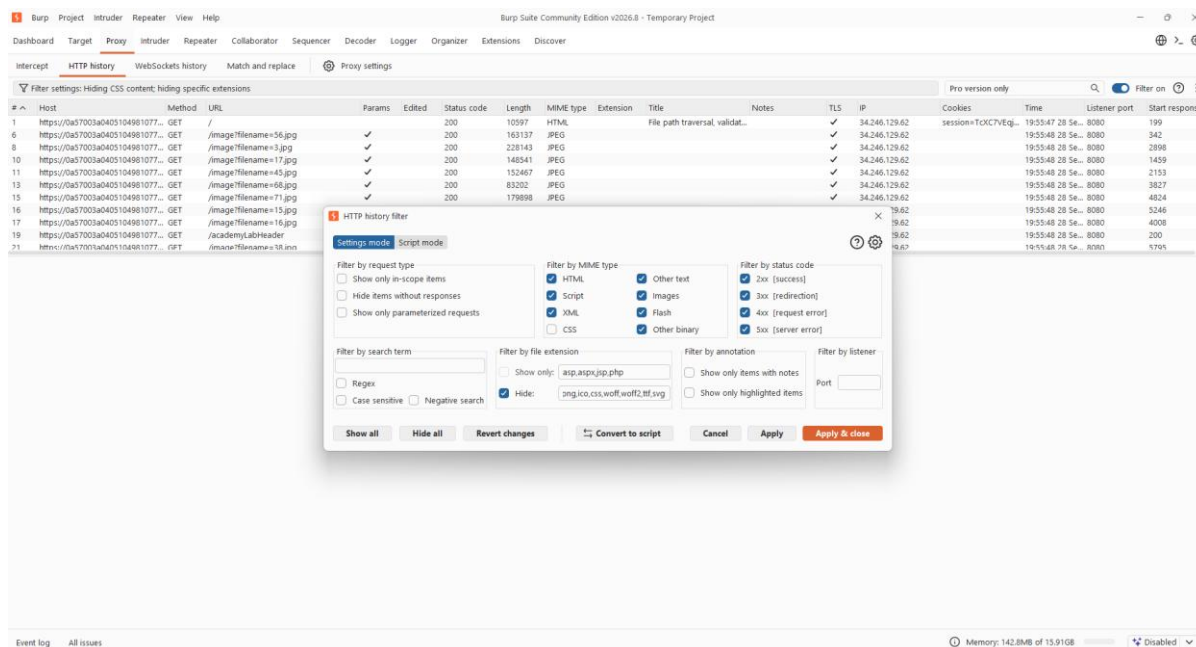
Impacto en la Triada CIA: Esta vulnerabilidad compromete de manera directa la "Confidencialidad" de la información, ya que expone datos sensibles del sistema operativo.

Perspectiva OWASP: Clasificada dentro de la categoría de *Broken Access Control* (Control de Acceso Roto), ocurre cuando la aplicación utiliza la entrada del usuario para construir una ruta de archivo sin validar o sanear adecuadamente dicha entrada, permitiendo escapar de la estructura de directorios autorizada.

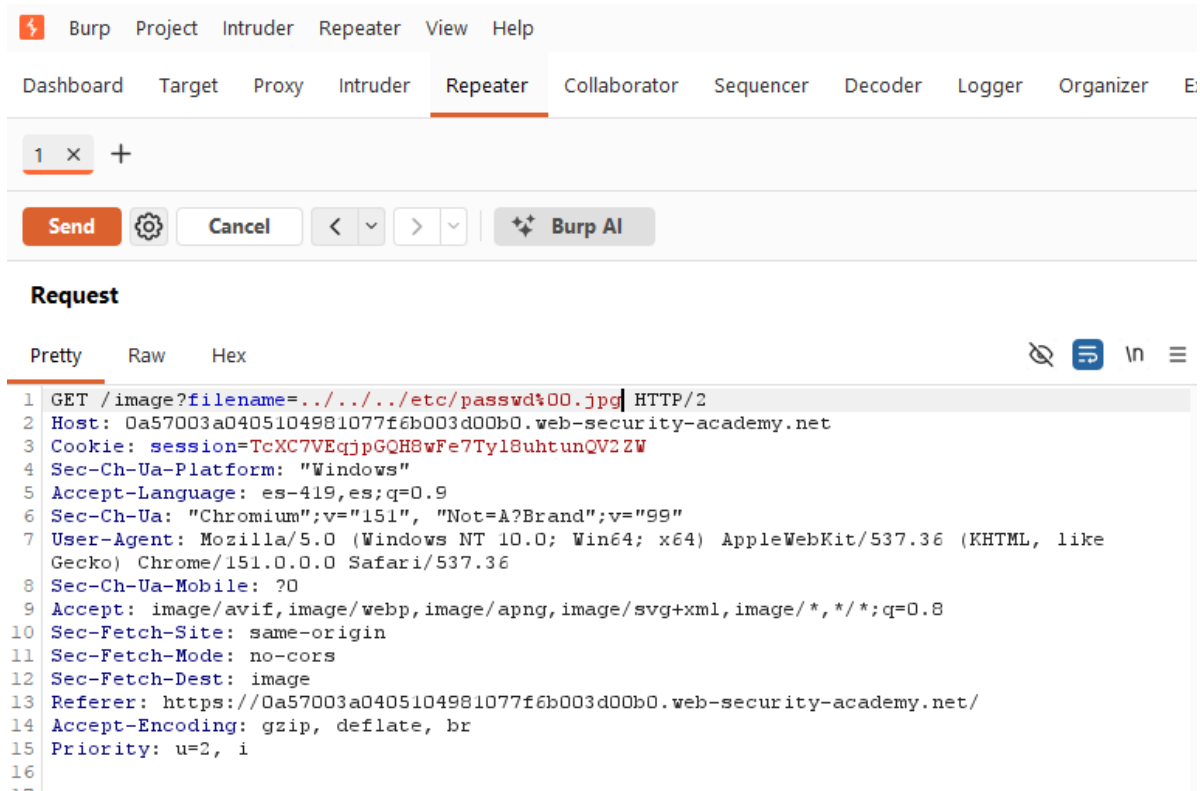
Procedimiento



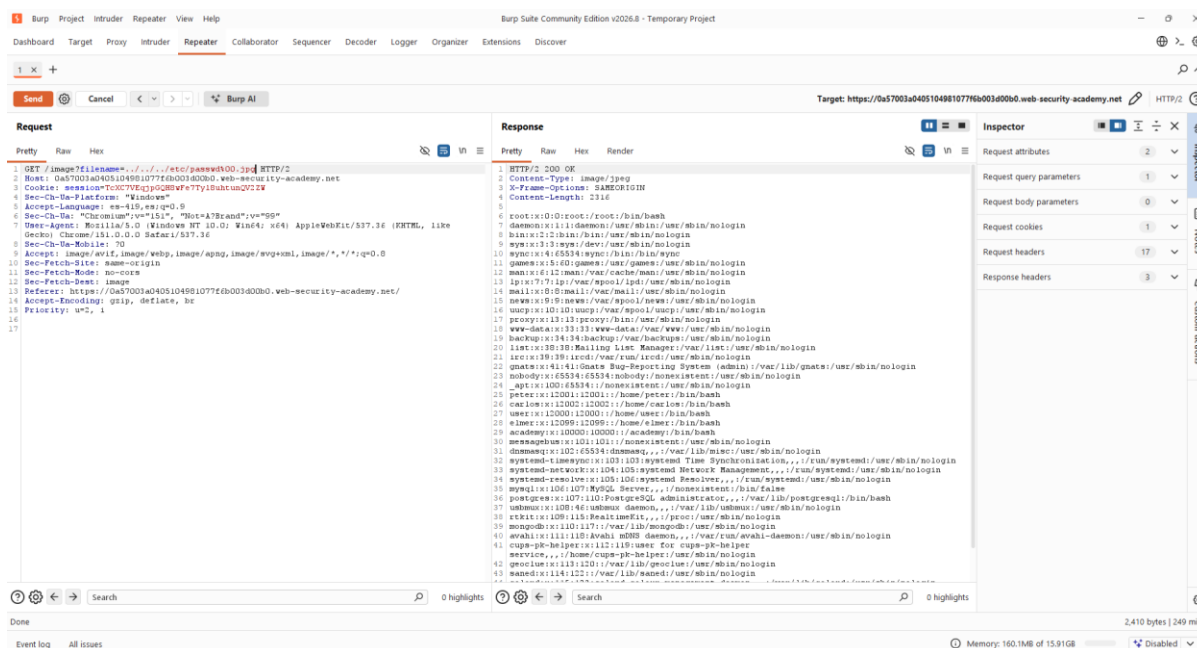
Se ingresó a la tienda virtual del laboratorio, en la cual podemos ver que carga varias imágenes de productos.



Durante la fase de reconocimiento en Burp Suite, se identificó un patrón inseguro en las peticiones GET hacia /image mediante el parámetro filename. Para poder visualizar estas peticiones en el HTTP history, fue necesario ajustar el filtro y habilitar la casilla 'Images' dentro de 'Filter by MIME type', ya que por defecto estaba desmarcada y ocultaba las peticiones hacia recursos de tipo imagen.



Preparamos el payload combinando una secuencia de traversal con un byte nulo seguido de la extensión esperada: `../../../../etc/passwd%00.jpg`. Con esto, se busca que la aplicación valide únicamente el final de la cadena (`.jpg`) y la acepte como válida, mientras que el sistema de archivos, al interpretar el `%00` como terminador de cadena, ignore la extensión y procese únicamente `../../../../etc/passwd`.



Damos clic en "Send" y podemos observar que tuvimos éxito y tenemos acceso al archivo passwd.

Explicación del Payload

El parámetro filename indica al servidor qué archivo leer del disco duro. En este laboratorio, la aplicación valida que la cadena recibida termine con una extensión permitida, como .jpg, asumiendo que esto restringe el acceso únicamente a archivos de imagen. Al construir el payload `../../../../etc/passwd%00.jpg`, la validación de extensión se cumple, ya que la cadena efectivamente termina en .jpg. Sin embargo, el byte nulo (%00) es interpretado por el sistema de archivos subyacente como el fin de la cadena, provocando que todo lo que sigue después (incluyendo .jpg) sea descartado. El sistema termina procesando únicamente `../../../../etc/passwd`, lo que permite ascender en la jerarquía de directorios y acceder al archivo objetivo, sin que la extensión falsa impida la explotación.

Mitigación Recomendada

- **Evitar entradas directas:** Lo más efectivo es evitar, lo más que se pueda, pasar la entrada directa al sistema de archivos. En su lugar, se podrían usar identificadores en una base de datos para localizar un archivo.
- **No confiar en la validación:** verificar que un nombre de archivo termine con cierta extensión no impide el acceso a rutas arbitrarias si el resto de la cadena no ha sido saneado. La extensión no debe ser tratada como un mecanismo de control de acceso al sistema de archivos.
- **Rechazar bytes nulos:** la aplicación debe detectar y rechazar cualquier entrada que contenga bytes nulos (%00) u otros caracteres de control antes de procesarla, ya que estos pueden ser interpretados de forma distinta entre el lenguaje de aplicación y el sistema de archivos subyacente.
- **Rutas Absolutas y canonicalización:** Tras recibir la entrada, la aplicación debe anexarla al directorio base estricto y utilizar funciones de canonicalización (ej. `realpath()` o `os.path.abspath()`), verificando que la ruta resultante comience exactamente con el directorio autorizado.

Referencias

OWASP. (s.f.). *Path Traversal*. OWASP Community. Recuperado el 28 de septiembre de 2026, de https://community.owasp.org/attacks/Path_Traversal